

Modelo Operacional — Gestão do Risco da Cadeia de Fornecimento em 4 Camadas

Síntese executiva para entidades essenciais e importantes · Ciclo do Negócio de Cibersegurança

O aviso que fundamenta tudo

Para uma entidade essencial, a gestão do risco da cadeia de fornecimento não pode limitar-se à citação de referenciais ou à afirmação genérica de conformidade — seria uma abordagem frágil e pouco defensável em auditoria, supervisão ou incidente. O modelo assenta em quatro camadas complementares: **risco → contrato → evidência → monitorização**.

Camada 1 · Risco do fornecedor — classificar antes de exigir

Classificar cada fornecedor pelo risco que introduz nos serviços críticos, sistemas, dados e continuidade. As perguntas mínimas:

- Que sistemas, processos ou serviços críticos suporta? (o fornecedor herda a criticidade da função que toca)
- Tem acesso a dados pessoais, informação sensível ou classificada? Tem acesso remoto aos nossos sistemas?
- O serviço é crítico para a continuidade? Existe dependência excessiva? É facilmente substituível?
- Que impacto teria a sua falha, indisponibilidade ou compromisso? Há subcontratantes relevantes?

Resultado: distinguir fornecedores de baixo risco de fornecedores críticos — a exigência indiferenciada é burocrática, ineficiente e não é gestão de risco. Instrumento: Matriz de Classificação de Fornecedores (Tier 1/Tier 2).

Camada 2 · Requisitos contratuais — exigir onde tem força

Para fornecedores críticos e relevantes, os requisitos entram no contrato (em contratação pública: no caderno de encargos). A considerar:

- MFA obrigatório nos acessos relevantes · regras claras para acessos remotos · gestão de vulnerabilidades e correções
- Notificação de incidentes em prazos definidos (horas, para críticos) · contactos técnicos e de segurança definidos
- Controlo e comunicação de subcontratantes · localização, tratamento e transferência de dados · confidencialidade e proteção de dados
- Backups e recuperação mínimos · requisitos de continuidade · logging, retenção e disponibilização de registos
- Direito de auditoria OU de solicitação de evidências · cessação contratual com devolução/eliminação de dados

O ponto crítico: o que não estiver no contrato dificilmente será exigível depois. Pedir "boas práticas" genéricas não chega. Instrumento: Cláusulas Contratuais de Segurança (13 cláusulas com texto-modelo).

Camada 3 · Evidência operacional — demonstrar, não declarar

Exigir evidências proporcionais ao risco. Não basta o fornecedor declarar que é seguro; deve demonstrá-lo:

- Certificação (ISO/IEC 27001, SOC 2, ENS, Cyber Essentials ou equivalente) — verificando validade e ÂMBITO
- Políticas (segurança, acessos), BCP/DRP e evidência de TESTES de recuperação — o plano exercitado, não o plano arquivado

- Gestão de vulnerabilidades (resumo/relatório) · modelo de gestão de incidentes · contacto de segurança para urgências
- Matriz de subcontratantes · formação/sensibilização · procedimentos de backup, retenção e restauro

Para críticos: evidência REGULAR, não apenas na contratação — a segurança do fornecedor é uma condição operacional acompanhada, não um documento entregue uma vez. Instrumento: Questionário de Due Diligence (54 perguntas, semáforos).

Camada 4 · Monitorização contínua — o contrato não é o fim

- Reavaliação periódica do risco · revisão anual de evidências (Tier 1) · registo de incidentes e falhas do fornecedor
- Revisão dos acessos atribuídos · validação de SLA · acompanhamento de alterações ao serviço e novos subcontratantes
- Revisão ANTES da renovação contratual — renovar automaticamente sem reavaliar o risco é má prática
- Testes de continuidade/recuperação quando aplicável · atualização da avaliação a cada alteração material

A documentação ENISA — que documento serve para quê

A documentação da ENISA é suporte metodológico — não substitui o modelo interno de gestão de risco. A articulação:

Documento (todos gratuitos)	Para que serve na prática
Good Practices for Supply Chain Cybersecurity (2023)	Base para políticas, checklists e requisitos de avaliação de fornecedores
Threat Landscape for Supply Chain Attacks (2021)	Justificar o risco e sensibilizar a gestão de topo (4× mais ataques; metade APT)
Supply Chain Integrity — ICT risks and challenges (2015)	Enquadrar riscos de integridade, dependência tecnológica e componentes comprometidos
Guidelines for Securing the Internet of Things (2020)	Quando há sensores, dispositivos ligados, sistemas industriais ou infraestruturas distribuídas
Interoperable EU Risk Management Framework	Integrar o risco da cadeia no processo global de gestão de risco
NIS2 Technical Implementation Guidance (2025)	Ligar requisitos legais a medidas técnicas e evidências auditáveis

A pergunta certa (para o board, para o auditor, para ti)

A pergunta não é apenas «o fornecedor cumpre?». É: **«que risco este fornecedor introduz nos nossos serviços essenciais, que evidência temos desse risco, e que capacidade temos para continuar a operar se ele falhar?»**

A conclusão prática: transformar a documentação de referência num modelo operacional PRÓPRIO — com critérios de classificação, requisitos contratuais, evidências mínimas e monitorização contínua. Os instrumentos estão na área Templates do curso.